

Assignment: OTP-Based Login System with Logging

Objective

Design and develop a backend authentication system that allows users to log in using Email or Mobile Number through One-Time Password (OTP). The system must support OTP generation, verification, resend functionality, and complete audit logging.

Functional Requirements

1. Send OTP

- Accept email or mobile number as input.
- Validate identifier format.
- Check if user exists in database.
- If user does not exist, send OTP first and then create the user record.
- Generate and store OTP securely in database.
- Do not return OTP in API response.

2. Verify OTP

- Accept identifier and OTP.
- Validate OTP correctness and expiry.
- Track failed verification attempts.
- Block verification after maximum allowed attempts.
- On success, mark OTP as verified and complete login.

3. Resend OTP

- Allow OTP resend with rate limits and cooldown.
- Generate a new OTP and invalidate the previous one.
- Store resend count and OTP status changes.

Logging Requirement (Mandatory)

- Log every step of each API request into database.
- Logs must include API name, step, status, message, timestamp, and unique trace ID.
- Logs should allow full audit of OTP lifecycle and user actions.

Data Storage

- Users table
- OTP requests table (status, expiry, attempts, resends)
- Audit logs table
- OTP must not be stored in plain text.

Deliverables

- Source code
- Database schema/script
- API documentation (Postman or README)
- Sample data showing logs and OTP records